Controls and Compliance Checklist

Company: Botium Toys
Audit Type: Internal Security Audit
Framework: NIST Cybersecurity Framework (CSF)
Date: 12.10.2026
Auditor: REZZODAN

Part 1: Controls Assessment Checklist

Select "Yes" or "No" to answer: Does Botium Toys currently have this control in place?

#	Control	Yes	No	Notes
1	Least Privilege		✅	All employees have access to internally stored data, including cardholder data and PII/SPII. Access controls for least privilege are not implemented.
2	Disaster Recovery Plans		✅	No disaster recovery plans currently in place.
3	Password Policies	✅		A password policy exists, but requirements are nominal and not in line with current minimum complexity requirements.
4	Separation of Duties		✅	Separation of duties has not been implemented.
5	Firewall	✅		The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
6	Intrusion Detection System (IDS)		✅	The IT department has not installed an IDS.
7	Backups		✅	The company does not have backups of critical data.

8	Antivirus Software	✅		Antivirus software is installed and monitored regularly by the IT department.
9	Manual Monitoring, Maintenance, and Intervention for Legacy Systems	✅		Legacy systems are monitored and maintained, but there is no regular schedule and intervention methods are unclear.
10	Encryption		✅	Encryption is not used to ensure confidentiality of customers' credit card information.
11	Password Management System		✅	No centralized password management system exists to enforce password policy requirements.
12	Locks (Offices, Storefront, Warehouse)	✅		The physical location has sufficient locks.
13	Closed-Circuit Television (CCTV) Surveillance	✅		Up-to-date CCTV surveillance is in place.
14	Fire Detection/Prevention (Fire Alarm, Sprinkler System, etc.)	✅		Functioning fire detection and prevention systems are in place.

Part 2: Compliance Checklist

Select "Yes" or "No" to answer: Does Botium Toys currently adhere to this compliance best practice?

PCI DSS (Payment Card Industry Data Security Standard)

#	Best Practice	Yes	No	Notes
1	Only authorized users have access to customers' credit card information.		✅	All employees have access to internally stored data and may be able to access cardholder data.

2	Credit card information is stored, accepted, processed, and transmitted internally in a secure environment.		✅	Encryption is not used to ensure confidentiality of credit card information.
3	Implement data encryption procedures to better secure credit card transaction touchpoints and data.		✅	Encryption is not currently implemented.
4	Adopt secure password management policies.		✅	Password policy requirements are nominal; no centralized password management system.

GDPR (General Data Protection Regulation)

#	Best Practice	Yes	No	Notes
1	E.U. customers' data is kept private/secured.	✅		Privacy policies, procedures, and processes are developed and enforced.
2	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	✅		The IT department has established a plan to notify E.U. customers within 72 hours.
3	Ensure data is properly classified and inventoried.		✅	There is inadequate management of assets; assets have not been properly identified or classified.
4	Enforce privacy policies, procedures, and processes to properly document and maintain data.	✅		Privacy policies are enforced among IT department members and other employees.

SOC (System and Organizations Controls — SOC 1, SOC 2)

#	Best Practice	Yes	No	Notes

1	User access policies are established.	✅	Access controls for least privilege and separation of duties have not been implemented.
2	Sensitive data (PII/SPII) is confidential/private.	✅	All employees have access to PII/SPII; encryption is not used.
3	Data integrity ensures the data is consistent, complete, accurate, and has been validated.	✅	The IT department has ensured availability and integrated controls to ensure data integrity.
4	Data is available to individuals authorized to access it.	✅	The IT department has ensured availability of data.

Part 3: Recommendations (Optional)

Based on the risk assessment, Botium Toys should prioritize the following controls and compliance measures to reduce risks to assets and improve security posture:

1. **Implement Least Privilege and Separation of Duties** — Currently, all employees have access to all data, creating a high risk of insider threat or accidental data exposure.
2. **Implement Encryption for Cardholder Data** — PCI DSS requires encryption of credit card information at rest and in transit. Without it, the company faces fines and data breach risks.
3. **Install an Intrusion Detection System (IDS)** — To detect and respond to anomalous or malicious traffic.
4. **Develop a Disaster Recovery Plan and Implement Backups** — To ensure business continuity in case of an incident.
5. **Implement a Centralized Password Management System** — To enforce password policy and reduce password fatigue.
6. **Conduct an Asset Inventory and Classification** — Without knowing what assets exist, it is impossible to protect them effectively.
7. **Establish a Regular Maintenance Schedule for Legacy Systems** — To ensure timely intervention and reduce risk from end-of-life systems.
8. **Strengthen the Password Policy** — Minimum 8 characters, combination of letters, numbers, and special characters.
9. **Encrypt All Sensitive Data (PII/SPII)** — To ensure confidentiality and comply with GDPR and SOC requirements.
